

Комплексна система захисту інформації

Галузевий профіль для месенджера (20)

Зміст

Зміст

1	AC	1
1.1	УПРАВЛІННЯ ПАРАЛЕЛЬНОЮ СЕСІЄЮ (AC-10)	1
1.1.1	id-spe-ac-19-1	1
1.1.2	id-spe-ac-19-5	2
2	AU	2
2.1	НЕСПРОСТОВНІСТЬ (AU-10)	2
2.1.1	id-spe-au-10-5	2
3	IA	2
3.0.1	id-spe-ia-5-12	3
3.1	id-spe-ia-7	3
4	MP	3
4.1	id-spe-mp-6	3
5	SC	5
5.1	id-spe-sc-5	5
5.1.1	id-spe-sc-8-1	5
5.1.2	id-spe-sc-8-2	5
5.2	ВСТАНОВЛЕННЯ КЛЮЧАМИ (SC-12)	6
5.3	id-spe-sc-17	6
5.4	id-spe-sc-20	6
5.5	id-spe-sc-21	7
5.6	id-spe-sc-22	7
5.7	АВТЕНТИФІКАЦІЯ СЕСІЇ (SC-23)	8
5.7.1	id-spe-sc-28-1	8
5.8	id-spe-sc-49	8
5.9	АПАРАТНИЙ ЗАХИСТ (SC-51)	9

Анотація

Галузевий профіль — розробляється для забезпечення конфіденційності, цілісності повідомлень та управління сесіями в месенджері.

1. AC

Клас заходів захисту AC — УПРАВЛІННЯ ДОСТУПОМ

Цей клас зосереджується на обмеженні доступу до інформаційних систем, ресурсів та функцій лише для авторизованих користувачів, програм і пристроїв.

Перелік заходів захисту: Управління паралельною сесією (AC-10); Id-spe-ac-19-1; Id-spe-ac-19-5.

1.1. УПРАВЛІННЯ ПАРАЛЕЛЬНОЮ СЕСІЄЮ (АС-10)

Обмежити кількість одночасних сеансів для кожного [Призначення: визначеного організацією облікового запису та/або типу облікового запису] до [Призначення: визначеної організацією кількості].

No: 1

Name: ac_10_01

Type: integer

Default: 30

Кількість одночасних сеансів для кожного облікового запису та/або типів облікових записів обмежена кількістю

No: 2

Name: ac_10_odp_02

Type: integer

Default: 30

Визначено кількість одночасних сеансів, дозволених для кожного облікового запису та/або типу облікового запису

1.1.1. id-spe-ac-19-1

No: 1

Name: ac_19_1_01

Type: string

Default: nil

КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ВИКОРИСТАННЯ ПИСЬМОВИХ ТА ПОРТАТИВНИЙ ПРИСТРОЇВ ДЛЯ ЗБЕРІГАННЯ ДАНИХ [Вилучено: Включено в МР-07]

1.1.2. id-spe-ac-19-5

Немає параметрів для цього контролю.

2. AU

Клас заходів захисту AU — АУДИТ ТА ПІДЗВІТНІСТЬ

Цей клас забезпечує можливість відстеження дій у системі, генерування, захист та аналіз записів аудиту для виявлення порушень політики безпеки.

Перелік заходів захисту: Неспростовність (AU-10); Id-spe-au-10-5.

2.1. НЕСПРОСТОВНІСТЬ (AU-10)

Надавайте неспростовні докази того, що особа (або процес, який діє від імені особи) виконала [Призначення: дії, визначені організацією, на які поширюється принцип неспростовності].

No: 1
 Name: au_10_01
 Type: list
 Default: ["admin", "security_officer"]

Надаються неспростовні докази того, що особа (або процес, що діє від імені особи) виконала дії

No: 2
 Name: au_10_odp
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Визначено дії, на які поширюється принцип неспростовності

2.1.1. id-spe-au-10-5

No: 1
 Name: au_10_5_01
 Type: string
 Default: nil

НЕСПРОСТОВНІСТЬ - ЦИФРОВІ ПІДПИСИ [Вилучено: Включено до SI-07]

3. ІА

Клас заходів захисту ІА — ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ

Цей клас відповідає за однозначне розпізнавання користувачів або пристроїв та підтвердження їхньої справжності перед наданням доступу до системи.

Перелік заходів захисту: Id-spe-ia-5-12; Id-spe-ia-7.

3.0.1. id-spe-ia-5-12

No: 1
 Name: ia_5_12_odp
 Type: string
 Default: "автоматизований засіб моніторингу"

Визначено вимоги до якості біометрії; для біометричної автентифікації використовувати механізми, які задовольняють вимоги

3.1. id-spe-ia-7

No: 1
 Name: ia_7_01
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Впроваджено механізми автентифікації в криптографічний модуль, який відповідає вимогам чинних законів, виконавчих розпоряджень, директив, політик, правил, стандартів та рекомендацій для такої автентифікації

4. МР

Клас заходів захисту МР — ЗАХИСТ НОСІЇВ ІНФОРМАЦІЇ

Цей клас спрямований на безпечне зберігання, транспортування, використання та знищення як цифрових, так і паперових носіїв інформації.

Перелік заходів захисту: Id-spe-mp-6.

4.1. id-spe-mp-6

а. Очищувати [Призначення: визначені організацією системні носії] перед утилізацією, випуском за межі організаційного контролю, або перед повторним використанням [Призначення: методами та процедурами очищення, визначеними організацією].

б. Використовувати механізми очищення зі стійкістю та цілісністю, що відповідає категорії безпеки або рівню секретності інформації.

No: 1

Name: mp_6_a_01

Type: string

Default: nil

Носії інформації системи перед утилізацією піддаються очищенню за допомогою методів та процедур очищення

No: 2

Name: mp_6_a_02

Type: string

Default: nil

Носії інформації системи очищаються за допомогою методів та процедур очищення перед випуском за межі контрольованої зони

No: 3

Name: mp_6_a_03

Type: string

Default: nil

Носії інформації системи очищуються за допомогою методів і процедур очищення перед повторним використанням

No: 4

Name: mp_6_b

Type: string

Default: "автоматизований засіб моніторингу"

Застосовуються механізми очищення, надійність і цілісність яких відповідає категорії безпеки або рівню секретності інформації

No: 5

Name: mp_6_odp_01

Type: string

Default: nil

Визначено носії інформації системи, які підлягають очищенню перед утилізацією

No: 6

Name: mp_6_odp_02

Type: string

Default: nil

Визначено носії інформації системи, які підлягають очищенню перед випуском за межі контрольованої зони

No: 7

Name: mp_6_odp_03

Type: string

Default: nil

Визначені носії інформації системи, що підлягають очищенню перед повторним використанням

No: 8

Name: mp_6_odp_04

Type: string

Default: nil

Визначено методи та процедури очищення, які слід використовувати для очищення перед утилізацією

No: 9

Name: mp_6_odp_05

Type: string

Default: nil

Визначено методи та процедури очищення, які слід використовувати для очищення перед випуском за межі контрольованої зони

No: 10

Name: mp_6_odp_06

Type: string

Default: nil

Визначено методи та процедури очищення, які слід використовувати для очищення перед повторним використанням

5. SC

Клас заходів захисту SC — ЗАХИСТ ІНФОРМАЦІЙНОЇ СИСТЕМИ ТА

Цей клас охоплює механізми захисту інформації під час її передачі мережами зв'язку, криптографічний захист та ізоляцію критичних компонентів.

Перелік заходів захисту: Id-spe-sc-5; Id-spe-sc-8-1; Id-spe-sc-8-2; Встановлення ключами (SC-12); Id-spe-sc-17; Id-spe-sc-20; Id-spe-sc-21; Id-spe-sc-22; Автентифікація сесії (SC-23); Id-spe-sc-28-1; Id-spe-sc-49; Апаратний захист (SC-51).

5.1. id-spe-sc-5

- a. [Призначення: захистити від; Обмежити] наслідки наступних типів подій відмови в обслуговуванні (DoS): [Призначення: визначені організацією типи подій відмови в обслуговуванні];
- b. Застосувати наступні заходи захисту для досягнення мети відмови обслуговування [Призначення: заходи захисту визначені організацією, за типом події відмови в обслуговуванні].

No: 1

Name: sc_5_odp_01

Type: string

Default: nil

Визначені типи подій відмов в обслуговуванні, від яких потрібно захищати або обмежувати; SC-05_ODP[02] вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {захистити від; обмежити}

5.1.1. id-spe-sc-8-1

No: 1
Name: sc_8_1_odp
Type: string
Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {запобігти несанкціонованому розголошенню інформації; виявити зміни в інформації}

5.1.2. id-spe-sc-8-2

No: 1
Name: sc_8_2_01
Type: string
Default: nil

КОНФІДЕНЦІЙНІСТЬ ТА ЦІЛІСНІСТЬ ПЕРЕДАЧІ - ПОПЕРЕДНЯ І ПОСТОБРОБКА МЕТА ОЦІНКИ:
Визначити, чи:

No: 2
Name: sc_8_2_odp
Type: string
Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {конфіденційність; цілісність}

5.2. ВСТАНОВЛЕННЯ КЛЮЧАМИ (SC-12)

Встановити та управляти криптографічними ключами для криптографічних засобів, які використовуються в системі відповідно до [Призначення: визначені організацією вимоги до генерації, поширення, зберігання, доступу та знищення ключів].

No: 1
Name: sc_12_01
Type: string
Default: "AES-256-GCM"

Встановлюються криптографічні ключі, коли в системі використовується криптографія відповідно до < SC-12_ODP вимог >

No: 2
Name: sc_12_02
Type: string
Default: "AES-256-GCM"

Здійснюється управління криптографічними ключами, коли в системі використовується криптографія, відповідно до вимог

No: 3
Name: sc_12_odp
Type: string
Default: nil

Визначені вимоги до генерації, розповсюдження, зберігання, доступу та знищення ключів

5.3. id-spe-sc-17

- a. Випускати сертифікати відкритого ключа відповідно до [Призначення: визначеної організації політики сертифікації];
- b. Отримувати сертифікати відкритого ключа від затвердженого постачальника послуг.

Немає параметрів для цього контролю.

5.4. id-spe-sc-20

- a. Надати додаткові дані автентифікації та перевірки цілісності джерела даних разом з офіційними даними розпізнавання імен, які система повертає у відповідь на запити дозволу імен/адрес.
- b. Надати засоби для вказання статусу безпеки дочірніх зон і (якщо дочірня зона підтримує служби безпечного дозволу) забезпечити перевірку ланцюга довіри між батьківськими та дочірніми доменами при роботі в складі розподіленого ієрархічного простору імен.

Немає параметрів для цього контролю.

5.5. id-spe-sc-21

Зробити запит та виконати перевірку автентичності джерела даних і перевірку цілісності даних у відповідях на дозвіл імен/адрес, які система отримує від уповноважених джерел.

No: 1

Name: sc_21_01

Type: string

Default: nil

Реалізується запит перевірки автентичності джерела даних для відповідей на запит дозволу імен/адрес, які система отримує від авторитетних джерел

No: 2

Name: sc_21_02

Type: string

Default: nil

Реалізується запит автентифікація походження даних на основі відповідей з дозволу імен/адрес, які система отримує від авторитетних джерел

No: 3

Name: sc_21_03

Type: string

Default: nil

Реалізується запит перевірки цілісності даних для відповідей на запит дозволу імен/адрес, які система отримує від авторитетних джерел

No: 4

Name: sc_21_04

Type: string

Default: nil

Виконується перевірка цілісності даних для відповідей на запит про дозвіл імен/адрес, які система отримує від авторитетних джерел

5.6. id-spe-sc-22

Переконалися, що системи, які спільно надають послуги розпізнавання імен/адрес для організації, є відмовостійкими та забезпечують поділ внутрішніх і зовнішніх ролей.

No: 1

Name: sc_22_01

Type: string

Default: nil

Є системи, які спільно надають послуги з визначення імен/адрес для організації, відмовостійкими

No: 2

Name: sc_22_02

Type: string

Default: nil

Реалізовано в системах, які спільно надають послуги з вирішення імен/адрес для організації, внутрішній розподіл ролей

No: 3

Name: sc_22_03

Type: string

Default: nil

Реалізовано в системах, які спільно надають послуги з вирішення імен/адрес для організації, зовнішній розподіл ролей

5.7. АВТЕНТИФІКАЦІЯ СЕСІЇ (SC-23)

Забезпечити автентифікацію сеансів зв'язку.

No: 1

Name: sc_23_01

Type: string

Default: nil

Захищено автентифікацію сеансів зв'язку

5.7.1. id-spe-sc-28-1

No: 1

Name: sc_28_1_01

Type: string

Default: "AES-256-GCM"

Реалізовані криптографічні механізми для запобігання несанкціонованому розкриттю інформації, що знаходиться в стані спокою на системних компонентах або носіях

No: 2
 Name: sc_28_1_02
 Type: string
 Default: "AES-256-GCM"

Реалізовані криптографічні механізми для запобігання несанкціонованій модифікації інформації, що знаходиться в стані спокою на системних компонентах або носіях

5.8. id-spe-sc-49

Впровадити механізми апаратного поділу та застосування політики між [Призначення: домени безпеки, визначені організацією].

No: 1
 Name: sc_49_01
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Впроваджено механізми апаратного розділення та застосування політик між доменами безпеки

No: 2
 Name: sc_49_odp
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Визначені домени безпеки, які потребують апаратного розділення та механізмів забезпечення дотримання політики

5.9. АПАРАТНИЙ ЗАХИСТ (SC-51)

- a. Перевіряти правильність роботи [Призначення: визначені організацією функції безпеки та приватності].
- b. Виконувати перевірку [Вибір (один або кілька): [Призначення: визначені організацією системні перехідні стани]; за командою користувача з відповідними повноваженнями; [Призначення: визначена організацією частота]].
- c. Повідомляти [Призначення: визначені організацією персонал або посадові особи] про невдалі перевірки безпеки та приватності.
- d. [Вибір (один або кілька): Вимкнути систему; Перезапустити систему; [Призначення: визначені організацією альтернативні дії]], коли виявляються аномалії.

No: 1
 Name: sc_51_odp_01
 Type: string
 Default: nil

Визначено компоненти системної прошивки, потребують апаратного захисту від запису; які

No: 2
 Name: sc_51_odp_02
 Type: list
 Default: ["admin", "security_officer"]

Визначені уповноважені особи, які повинні виконувати процедури вимкнення та повторного ввімкнення апаратного захисту від запису; SC-51a. використовується апаратний захист від запису для компонентів мікропрограми системи; SC-51b.[01] впроваджено спеціальні процедури для уповноважених осіб для ручного вимкнення апаратного захисту від запису для модифікацій мікропрограми; SC-51b.[02] реалізовано спеціальні

процедури для уповноважених осіб для повторного увімкнення захисту від запису перед поверненням до робочого режиму